

HO/01/IT/2025-26/90

Date:22.05.2025

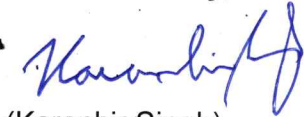
Circular to all Branches & Offices
Issued by Informtaion Technology Department

Re: Vulnerability Assessment & Penetration Testing (VAPT) Policy (Version 1.0) of the Bank

Branches & Offices are hereby informed that the Vulnerability Assessment & Penetration Testing (VAPT) Policy (Version 1.0) of the bank has been approved by the Hon'ble Board of Directors through agenda item no.10 in its meeting no.01(01/2025) dated 07.05.2025. The policy will come into force with immediate effect & validity of the policy is for next three years from the date of approval. The approved Vulnerability Assessment & Penetration Testing (VAPT) Policy is attached here with this circular.

Kindly bring the content of this policy in the notice of all staff members of the Branches/Offices.

Yours faithfully,



(Karanbir Singh)

General Manager

Enclosure: As above

P3

Vulnerability Assessment & Penetration Testing (VAPT) Policy

Version 1.0

**Uttar Pradesh Gramin Bank
Information Technology Department
Head Office, Lucknow**

Vulnerability Assessment & Penetration Testing (VAPT) Policy	Version 1.0
--	-------------

Document Name	Vulnerability Assessment & Penetration Testing (VAPT) Policy
Document ID	UPGB_VAPT_1.0
Document Owner	CISO
Document Version No.	1.0
Document Version Date	
Prepared By	Information Technology Department
Reviewed By	
Approved By	

Document Information**Version History**

Version No.	Version Date	Prepared by
1.0		

Current Version Reviewed by

Version No.	Designation
1.0	

Distribution List

Version No.	Name	Designation	Department
1.0	N.A.	All Departmental Heads and Heads of Controlling Offices.	All Departments, Controlling Offices and Branches

Table of Contents

Sr. No.	Particular	Page No.
01.	Policy Statement, Overview, Introduction, Scope, Definitions	04
02.	Roles & Responsibilities, Impact, Standards Addressed	05
03.	Standards and Guidelines	05-08
04.	Reference Document	08
05.	Exceptions, Policy Management & Version Control	09

1. Policy Statement

In order to identify vulnerabilities in the IT systems, it is imperative to conduct periodic VAPT exercise so that the same can be identified and mitigated to minimize risk to the organization in a cost effective manner.

2. Overview

To identify vulnerabilities, it is the practice for Banks to conduct internal and external scans and identify vulnerabilities. Vulnerability scanning is performed through the use of various automated tools. These tools may throw large number of false positives. In order to identify false positives, automated tools/manual skills and experience is required. Penetration testing should be performed by experts who employ manual and automated method to penetrate into the targeted systems. To ensure that vulnerabilities in the Bank's IT environment are promptly identified and protected from potential threats, penetration testing is conducted. These tests aim to evaluate the security posture of systems by answering the following: -

The project team must notify the Chief Information Security Officer (CISO) of any major changes.

- New applications accessible through external networks must undergo VAPT before being implemented in production. Identified vulnerabilities must be resolved before going live.
- Penetration testing must be performed by certified agencies with skilled personnel and appropriate tools.

Non-Disclosure Agreement must be signed with the vendors conducting penetration tests. - Testing should be planned in advance to minimize disruptions and avoid conducting tests during peak business hours.

Risk Assessment should be carried out to identify potential risks, and necessary precautions should be taken to mitigate them.

3. Introduction

This document addresses Policy, Standards and Guidelines and procedures related to conducting VAPT and its closure. This document will provide methodology to all the stakeholders for pre assessment, during and post assessment procedures to be followed to deal with the findings.

4. Scope

This Policy applies to all Bank staff as well as all Bank information resources including data, as well as the application and systems software including BOB RRB DC/DR.

5. Definitions

Vulnerability: Vulnerability is a weakness in the system.

Vulnerability Assessment: Process of identification of vulnerabilities in the system.

Threat Agent: A threat agent also known as attacker, takes advantage of vulnerability (weakness) in the system for some gains.

Exploit: A malware/Software designed to take advantage of vulnerability in the system.

Penetration Testing: Penetration testing involves attacking a system through exploiting vulnerabilities in the system. This is performed by the Ethical Hackers.

6. Roles and Responsibilities

ROLE	RESPONSIBILITIES
Business owner	Provide list of Business applications and initiate request for VAPT to Data Center, Closure of VAPT findings Ensuring VAPT of outsourced operations is performed by outsourced vendor through Cert-In empaneled vendor
IT Department/Data Center	Provide list of IT Infrastructure and applications and initiate request for VAPT to Data Center, closure of VAPT findings.
IT Security Team at Data Center	Coordinate with all the concerned for conducting VAPT, Ensure periodic VAPT are done and reports are submitted, facilitate closure of observations. Presentation of residual risks
Auditor/Consultant	Conducting external VAPT
Data Center Incharge/CISO	Conducting internal Vulnerability Assessment

7. Impact

THREAT	IMPACT	LIKELIHOOD
Non conducting periodic vulnerability assessment	High	Low
Not Identifying vulnerabilities in the system	High	Low
Not mitigating Vulnerabilities in the system in a timely manner	High	Moderate

8. Standards Addressed

8.1 ISO 27001:2013 Control(s)

- A.12.6 – Technical Vulnerability Management
 - A.12.6.1 Management of Technical Vulnerabilities
- A.12.7 – Information System Audit Considerations
 - A.12.7.1 Information Systems Audit Controls

9. Standards and Guidelines

9.1 Establishing and documenting the External VAPT Process

VAPT process can be broadly classified into following -3 broad phases.

- Pre Assessment Phase
- Assessment Phase
- Post Assessment Phase

9.1.1 Pre Assessment

9.1.1.1 Request for VAPT of Applications:

Business owners shall be making request to data center for VAPT. A meeting with VAPT consultant would be arranged by DC to proceed further in the matter. VAPT request for non-business applications shall be initiated by IT department.

For outsourced services, Business owner to ensure that VAPT is conducted when a change happens in application, Hardware or services or at least on yearly basis by the outsourced service provided.

9.1.1.2 Scheduling of VAPT:

Data Center team would chalk out broad schedule and the same shall be informed to concerned stakeholders such as business owners, IT, CISO etc. Critical applications are to be considered for VAPT as per Bank's BCP (Business continuity plan).

9.1.1.3 Inventory of Internet facing applications:

All applications would need to be informed to CISO by the respective Business owners. DC would maintain inventory of all the applications as per the following format.

- Business Owner:
- Name of the application
- Bank's application Administrator
- URL Address, if any
- Whether accessible from internet : Yes/No
- IP address : (Public and Private IP address)
- Application vendor
- Application modules and Interfaces
- Whether application is accessible through web browser, if yes details of compatible browsers.
- Whether application server is accessible through Mobile app. (If yes, details)
- Whether application is accessible through thick client. If yes, give details like name, version etc.
- Whether application is accessible from internet through API, web service etc. if yes, details
- Regulatory requirements of VAPT, if any
- Business owner to separately provide list of internet facing applications with Outsourced service providers to CISO.

9.1.1.4 Periodic Testing:

i) Business owner should inform launch of any application in advance to CISO so that appropriate planning for VAPT exercise can be done well in time, also it includes the change in existing application. Frequency of VAPT will depend on regulatory requirement and criticality of application, which will be decided by CISO in consultation with Business owner.

ii) Periodically conduct Vulnerability Assessment/Penetration Testing (VA/PT) of internet facing web/mobile applications, servers and network components throughout their lifecycle (pre-implementation, post implementation, after changes, etc.). VA of critical applications and those on DMZ shall be conducted at least once in every 6 months. PT shall be conducted at least once in a year.

iii) Application security testing of web/mobile applications should be conducted before going live and after every major changes in the applications.

iv) Penetration testing of public facing systems as well as other critical applications are to be carried out professionally qualified team. Findings of VA/PT and the Information Security/Information Technology Audit team as well as Top Management.

9.1.2 Assessment

During VAPT exercise, there may be large number of alerts generated at SOC (When SOC is implemented). IP address of the systems, from where penetration tests are conducted shall be advised by Consultant to DC. DC will inform internally to the concerned departments to avoid false alerts.

Vulnerability Assessment shall be carried out as per the industry best practices such as OWASP guidelines, known vulnerabilities databases, Mobile application security guidelines etc. and the same shall be part of the VAPT report.

Broadly, Risk Categorization to be done as per the following criteria.

Critical Risk	Weakness in controls that could severely impact the organization
High Risk	Weakness in controls that represent exposure to the organization or Risks that could seriously compromise the control framework, data integrity and/or Operational efficiency.
Medium	Potential weakness in controls, which could develop into an exposure or Issues that represent areas of concern and may impact controls. They should be addressed reasonably promptly.
Low	Potential weaknesses, in controls, which in combination with other weaknesses can develop into exposure. Suggested improvements not immediately/directly affecting controls
Informational	Potential weakness in Information disclosure which is not as per industry best practices.

Critical and High Risk findings shall be immediately brought to the notice of business owners. Business owners wherever required in consultation with IT department/Data Center shall close the critical risk finding immediately less than 24 hours and high risk findings within -24- hours. Details of the critical and High risk findings shall be kept confidential by all the concerned till these are remediated.

9.1.3 Post Assessment

Draft VAPT report shall be shared by DC with Business owner. Business owner will chalk out mitigation plan in consultation with IT department/vendor etc.

9.1.3.1 Exit Meeting:

Draft report shall be discussed with the concerned stakeholders during the meeting. Exit meeting shall be called within -3- days of receipt of the report by DC.

Following shall be discussed and recorded:

- Correctness of the observations in VAPT report and Risk rating of the observational finding.
- Task owner for closure of the findings.
- Timeline for closure of the findings (not exceeding the timelines mentioned in 9.1.3.2, however in case if closure of finding requires additional procurement, the same may be recorded)

Exit meeting shall be attended by Consultant, executive (not less than AGM rank) Business owner, Application administrator, Data Center-Incharge and CISO. Business owner may involve application vendor, if required. Draft report after the exit meeting shall be signed by the concerned officials.

9.1.3.2 Timelines for closure of VAPT findings:

- Critical Risk: Immediately (less than 24 Hours)
- High Risk: 24 Hours.
- Medium Risk : 7 Days
- Low Risk : 30 Days

Above timelines are maximum time limits for closure of the report findings. In case of any delay, risk for not closing the observation remains open.

9.1.3.3 Management Comments:

Business owner shall submit management comments to CISO on closure status of the findings on expiry of 30 days. CISO shall review comments and on acceptance the bank shall be made part of the final report.

9.1.3.4 Final Report:

Final report incorporating management comment shall be signed by the Business owner, Application owner (IT), Data Center Incharge, CISO and Consultant and the same shall be kept on record.

9.1.3.4 Risk Acceptance of open items:

Open Critical, high and medium risk items beyond 30 Days should be referred to ORMC by the DC/Bank for acceptance of the risk. Business owner while requesting for acceptance of the risk shall specify the justification for Risk acceptance. Risk can be accepted based on the following criteria:

- Technical feasibility: Where mitigation of risk is not technically feasible or the mitigation of risk will take prolong time.
- Cost of Mitigation of risk: Cost of mitigation of risk is very high as compared to the derived benefit of implementing the controls.
- Business impact on other applications or infrastructure components: Where mitigating controls may impact the other peripheral systems or components.

9.2 Internal Vulnerability Assessment:

Security Operations Centre ("Data center team in consultation with CISO" until SOC is implemented) will carry out internal Vulnerability Assessment at a defined periodic interval. For internal VA, only Post assessment process shall be followed as described above.

9.3 VAPT of Internet facing applications owned by outsourced service providers:

Following standard should be followed for VAPT of internet facing applications owned by outsourced service providers:

- Business owners to provide list of internet facing applications owned by outsourced service providers on quarterly basis to DC.
- Outsourced service provider shall be responsible to conduct VAPT of their internet facing applications through Cert-In empanelled tester.
- VAPT shall be performed at least on yearly basis and in case of Business critical applications, on half yearly basis.
- Business owner shall obtain VAPT report from outsourced service provider and submit to DC.
- In case of observance of Critical/High risk observations, Business owner shall decide on continuation of services with the outsourced service provider.
- DC shall review the report and monitor closure of VAPT open observations.
- Business owner shall incorporate appropriate clauses in service level agreements with the service provider.

10. Reference Document

Sr. NO	DOCUMENT NAME
1.	Information Security Policy
2.	NABARD's guidelines on Comprehensive Cyber Security Framework for Regional Rural Banks (RRBs) - A Graded Approach for time bound implementation issued vide EC No.33/DoS-08/2020 dated 06.02.2020 (Ref. No. NB.DoS.Pol.HO./3184/J-1/2019-20)

11. Exceptions

Where there is a justifiable business need that requires actions to be performed which are in conflict to this document, such exceptions shall be reported to the TOP Management and approval shall be obtained. Such approvals shall be valid for a pre-defined period after which it shall be re-evaluated and re-approved.

12. Policy Maintenance & Version Control

The validity of the policy shall be three years from the date of approval of the Board. In case the policy cannot be reviewed on or before due date, The Chairman is authorized for allowing to continue with the policy for further three months from the due date of review.

Any fresh/additional guidelines issued by RBI/NABARD/Sponsor Bank or any such statutory/regulatory/supervisory etc. body shall supersede this policy with concurrence of the Chairman subject to reporting/informing the Hon'ble Board.

End of document